

Physical Access Control

Remediation Guide — Identifying and Eliminating Unauthorized Access Vectors

Physical access control is the foundation of every security program. When an unauthorized person can walk through your front door, every firewall, encryption protocol, and security policy becomes irrelevant. This guide addresses the six most common physical access failures and provides actionable remediation steps for each.

1. Access Code and Lock Rotation

THE RISK

Former employees, contractors, and vendors often retain physical access long after their business relationship ends. If door codes haven't changed since the last employee departure, every person who has ever had that code still has it. This creates invisible backdoors that won't show up in any access log.

IMMEDIATE FIX — Implement This Week

Change all exterior door codes immediately. Set a calendar reminder to rotate codes quarterly.

If using physical keys, identify every unreturned key from the last 24 months. Rekey any door where keys are unaccounted for.

Post a simple tracking sheet near each access point to log when codes were last changed. This creates accountability without requiring new technology.

FULL REMEDIATION

Migrate from static codes to individualized access credentials (card, fob, or PIN per person). This allows you to revoke a single person's access without disrupting everyone else.

Implement an access credential lifecycle policy: every credential has an issue date, an expiration review date, and a revocation trigger tied to HR separation events.

Create a master access register documenting every entry point, the access method used, and the last rotation date. Review quarterly.

i WHAT THIS WON'T SOLVE ON ITS OWN

Individualized credentials solve the rotation problem, but they create a new one: credential management. Without a system that ties access provisioning to HR events (hiring, role changes, termination), gaps will reappear within months. Most organizations discover they need a formal access governance process that integrates physical and logical access — and that process needs to be tested against real-world evasion techniques to verify it actually works.

2. Visitor Sign-In and Escort Policy

THE RISK

Social engineers routinely impersonate vendors, delivery personnel, IT support, and job candidates to gain physical access. Without a structured visitor management process, the only barrier between an attacker and your server room is whether your receptionist asks a question.

IMMEDIATE FIX — Implement This Week

Implement a visitor log immediately — a simple paper sign-in sheet with name, company, purpose, host employee, and time in/out.

Require every visitor to be met by a named employee host. No unescorted visitors in any area beyond the lobby.

Create a visible badge system: visitors get a clearly different badge color than employees. This makes unauthorized presence obvious to everyone, not just security staff.

FULL REMEDIATION

Deploy a visitor management system (even a basic tablet-based one) that captures photo ID, prints a time-stamped badge, and automatically notifies the host employee.

Define and post zone access rules: public areas (lobby, conference rooms), restricted areas (offices, workspaces), and high-security areas (server rooms, records storage). Each zone has different escort requirements.

Train all employees — not just front desk staff — on how to approach an unescorted visitor. The phrase is simple: “Hi, can I help you find who you’re looking for?”

i WHAT THIS WON’T SOLVE ON ITS OWN

A visitor policy only works if employees actually enforce it. The gap between a written policy and real-world behavior is where most physical breaches occur. Organizations consistently find that employees won’t challenge a confident stranger, especially one in a uniform or carrying a clipboard. Knowing whether your team will actually follow the policy under pressure — versus on paper — requires testing it against realistic scenarios, not just training them on it.

3. Sensitive Area Segregation

THE RISK

If a single badge, key, or code opens both the front door and the server room, a single compromised credential gives an attacker access to everything. Flat access architectures turn every breach into a total compromise.

IMMEDIATE FIX — Implement This Week

Identify your three most sensitive physical locations (server room, records storage, executive offices, medication rooms, etc.).

Change the locks or codes on those areas to be different from general building access. Even a \$30 combination lock on a server room door is better than using the same code as the front door.

Restrict key/code distribution to named individuals. Create a written log of who has access to each sensitive area.

FULL REMEDIATION

Implement role-based physical access: employees only get access to the areas required for their job function. A marketing coordinator does not need server room access.

Deploy access controls that create audit logs — electronic card readers or biometric systems for high-security areas. You need to know who entered and when.

Conduct a quarterly access review: for each sensitive area, pull the list of people with access and verify every name still requires it. Remove anyone who doesn't.

i WHAT THIS WON'T SOLVE ON ITS OWN

Segregation creates layers, but layers only work if the boundaries hold. The question isn't whether your server room has a separate lock — it's whether someone can get through that lock using social engineering, tailgating, or a cloned credential. Layered access creates a false sense of security if the layers haven't been stress-tested by someone actually trying to defeat them.

4. Termination Access Revocation

THE RISK

Delayed access revocation after termination creates a window for data theft, sabotage, or unauthorized re-entry. A disgruntled former employee with active credentials is one of the highest-risk scenarios in physical security. Every hour of delay increases exposure.

IMMEDIATE FIX — Implement This Week

Create a same-day termination checklist. The moment HR processes a separation, physical access must be revoked: collect badges, deactivate cards, collect keys, change any shared codes the person knew.

Assign a single person (ideally in HR or facilities) as the owner of this checklist. No termination is complete until every item is checked.

Audit the last 12 months of departures. Verify that every former employee's access was actually revoked. If you find active credentials for departed staff, revoke them now.

FULL REMEDIATION

Integrate physical access revocation into your HR separation workflow so it's automatic, not manual. When someone is marked as terminated in HR, their badge deactivates.

Implement a 24-hour access review after every departure: did the checklist actually get completed? Who verified?

For involuntary terminations, coordinate with IT to simultaneously revoke physical and digital access. The escort-out process should include real-time confirmation that all systems show the person as deactivated.

i WHAT THIS WON'T SOLVE ON ITS OWN

Checklists and processes solve the known, planned departure. They don't address the risk window during the notice period, the contractor whose contract quietly expired, or the vendor whose access was granted for a "temporary" project 18 months ago. Most organizations have a significant population of forgotten access holders who don't appear on any departure list. Finding them requires a comprehensive audit that goes beyond HR records.

5. Tailgating Prevention

THE RISK

Tailgating — following an authorized person through a secured door — bypasses every access control and leaves zero audit trail. It exploits human politeness: holding the door open is a social norm that directly conflicts with security requirements. Most employees will not confront a stranger walking in behind them.

IMMEDIATE FIX — Implement This Week

Post signage at all access points: “One badge, one entry. Do not hold the door for others.” This gives employees social permission to not be polite.

Brief all employees: it is acceptable and expected to let the door close behind you, even if someone is right behind you. Provide a script: “Sorry, policy requires everyone to badge in separately.”

Identify your highest-risk entry points (parking garage doors, back entrances, loading docks) and prioritize monitoring at those locations.

FULL REMEDIATION

Install anti-tailgating physical controls at high-security entry points: turnstiles, mantraps (double-door vestibules), or optical sensors that detect multiple people per badge swipe.

Implement a tailgating reporting mechanism: if an employee observes someone tailgating, they can report it through a simple, non-punitive channel.

Conduct periodic tailgating awareness campaigns with real metrics: how many unauthorized entries were detected this quarter?

i WHAT THIS WON'T SOLVE ON ITS OWN

Signage and training change behavior temporarily, but social pressure to be polite is extremely persistent. The only way to know if your anti-tailgating measures are actually working is to test them under real conditions — not with a compliance checklist, but with someone actively attempting to tailgate during normal business hours. Organizations are consistently surprised by how easily their controls fail when tested by a practiced operator.

6. Security Camera Coverage and Footage Retention

THE RISK

Cameras without coverage gaps provide forensic evidence after a breach and deter opportunistic attacks. Compliance frameworks including HIPAA, SOC 2, and PCI DSS increasingly require video audit trails. Non-functional cameras or short retention periods mean that by the time you discover a breach, the evidence is already gone.

IMMEDIATE FIX — Implement This Week

Walk every entry/exit point and sensitive area. Document which ones have cameras, which cameras are actually recording, and which have blind spots.

Verify that all existing cameras are functional, recording, and accessible. It is common to discover cameras that have been non-operational for months.

Set retention to a minimum of 30 days. If your current system can't store 30 days, prioritize retention for entry/exit points and sensitive areas.

FULL REMEDIATION

Conduct a formal camera coverage assessment: map every entry/exit, sensitive area, hallway intersection, and parking area. Identify gaps.

Implement a camera health monitoring system that alerts when a camera goes offline or storage is nearing capacity.

Define a retention policy aligned with your compliance requirements (30 days minimum; 90 days recommended for regulated industries) and verify storage capacity supports it.

i WHAT THIS WON'T SOLVE ON ITS OWN

Cameras record what happens, but they don't prevent it. A complete coverage map still has blind spots you don't know about — angles that look covered on a diagram but have obstructions in practice, or areas where camera placement reveals the lens but doesn't capture faces. The gap between your camera map and your actual coverage is something that can only be identified by physically testing sight lines, which requires someone with experience in evasion and counter-surveillance techniques.

Implementation Priority

Organizations with limited resources should prioritize in this order:

- **Termination access revocation** — highest risk, lowest cost to fix
- **Access code rotation** — eliminates legacy backdoors immediately
- **Visitor management** — creates a visible deterrent and audit trail
- **Sensitive area segregation** — limits blast radius of any single breach
- **Tailgating prevention** — requires cultural change plus physical controls
- **Camera coverage** — highest cost, but essential for compliance and forensics

Critical note: Every remediation step in this guide can be implemented internally. However, the effectiveness of each control is ultimately determined by whether it holds up under adversarial pressure. Controls that look strong on paper routinely fail when tested by someone with training in physical access exploitation. The only way to validate your physical access controls is to subject them to realistic testing before a real adversary does it for you.